

# Annexe - CAHIER DES CHARGES

## Mission d'Architecture Système d'Information Multi-Sites

---

CLIENT  
**Ministère des Armées**

|                 |                                            |
|-----------------|--------------------------------------------|
| Référence       | CDC-SI-MULTISITES-2026                     |
| Version         | 1.0 — Document initial                     |
| Date d'émission | 2026                                       |
| Responsable     | Direction des Systèmes d'Information (DSI) |
| Statut          | Validé                                     |

# 1. Introduction et objet du document

Ce cahier des charges définit les exigences techniques, fonctionnelles, réglementaires et contractuelles pour la conception, le déploiement et l'exploitation d'un système d'information multi-sites hautement disponible, sécurisé et industrialisable au profit du Ministère des Armées.

Il constitue le document de référence pour la consultation des prestataires, la contractualisation et la recette des livrables.

## 2. Contexte et enjeux

### 2.1 Contexte organisationnel

Le Ministère des Armées exploite des systèmes d'information critiques répartis sur plusieurs sites industriels et opérationnels. La diversité géographique des sites, la criticité des traitements et les exigences de souveraineté numérique imposent une architecture rigoureusement conçue, conforme aux référentiels de sécurité nationaux.

### 2.2 Enjeux stratégiques

- Assurer la continuité d'activité en toute circonstance, y compris en cas de rupture WAN ou d'incident majeur sur un site
- Garantir la souveraineté et la maîtrise des données traitées, en conformité avec la Loi de Programmation Militaire (LPM)
- Industrialiser les pratiques d'exploitation pour réduire la dette technique et les risques liés à l'intervention humaine
- Répondre aux exigences de traçabilité, d'audit et de forensic imposées par les autorités de contrôle

### 2.3 Périmètre

Le périmètre couvre quatre sites interconnectés, des applications critiques à haute disponibilité, et l'ensemble des couches infrastructure (réseau, stockage, calcul, sécurité, observabilité).

## 3. Cadre réglementaire et normatif

L'ensemble de l'architecture doit être conforme aux référentiels et réglementations suivants :

| Référentiel                      | Domaine                | Exigences principales                                             |
|----------------------------------|------------------------|-------------------------------------------------------------------|
| RGS (ANSSI) v2.0                 | Sécurité SI            | Qualification des produits de sécurité, homologation des systèmes |
| LPM 2024-2030                    | Cybersécurité OIV      | Obligation de déclaration d'incidents, mesures de résilience      |
| SecNumCloud (ANSSI)              | Cloud souverain        | Hébergement sur infrastructure qualifiée si cloud public envisagé |
| PGSSI-S / IGI 1300               | Classification données | Gestion des données classifiées, cloisonnement DR/Secret          |
| RGPD                             | Données personnelles   | Minimisation, traçabilité, droit à l'effacement                   |
| NIS2 (transposition FR en cours) | Résilience numérique   | Gestion des risques cyber, notification d'incidents               |
| ISO/IEC 27001                    | SMSI                   | Référence pour la gestion de la sécurité de l'information         |

|                        |            |                                                               |
|------------------------|------------|---------------------------------------------------------------|
| <b>NIST SP 800-207</b> | Zero Trust | Architecture Zero Trust — référence pour la conception réseau |
|------------------------|------------|---------------------------------------------------------------|

*Note : En cas de traitement de données classifiées de niveau Secret Défense ou au-dessus, les contraintes PGSSI-S et IGI 1300 priment sur toute autre considération technique. Le prestataire devra détenir les habilitations correspondantes.*

## 4. Parties prenantes et gouvernance

### 4.1 Acteurs du projet

| Rôle                               | Entité                   | Responsabilités                                                      |
|------------------------------------|--------------------------|----------------------------------------------------------------------|
| <b>Maîtrise d'ouvrage (MOA)</b>    | DSI Ministère des Armées | Définition des besoins, validation des livrables, décision finale    |
| <b>Maîtrise d'ouvrage déléguée</b> | Responsable Technique SI | Suivi quotidien, recette technique, interface avec la MOE            |
| <b>Maîtrise d'œuvre (MOE)</b>      | Prestataire retenu       | Conception, déploiement, documentation, transfert de compétences     |
| <b>RSSI</b>                        | DSI — Pôle Cybersécurité | Validation des choix sécurité, homologation, audits                  |
| <b>Équipes métier</b>              | Directions concernées    | Expression des besoins, tests d'acceptance, validation fonctionnelle |
| <b>CALID / COMCYBER</b>            | Ministère des Armées     | Supervision cyber, gestion des incidents de niveau critique          |

### 4.2 Instances de gouvernance

- Comité de pilotage (COPIL) : mensuel — validation des jalons, arbitrages budgétaires, décisions stratégiques
- Comité technique (COTECH) : bi-hebdomadaire — suivi de l'avancement, résolution des points bloquants
- Comité de sécurité : à chaque jalon majeur — revue des choix sécurité, validation RSSI
- Revue de code et d'architecture : hebdomadaire — contrôle qualité laC, respect des standards

## 5. Volumétrie, dimensionnement et contraintes d'exploitation

### 5.1 Volumétrie cible

| Paramètre                                        | Valeur minimale | Valeur cible |
|--------------------------------------------------|-----------------|--------------|
| <b>Nombre d'utilisateurs actifs</b>              | 500             | 2 000        |
| <b>Connexions simultanées peak</b>               | 200             | 800          |
| <b>Volume de données (stockage primaire)</b>     | 50 To           | 200 To       |
| <b>Flux de logs journaliers</b>                  | 50 Go/jour      | 200 Go/jour  |
| <b>Nombre d'applications critiques hébergées</b> | 10              | 30           |
| <b>Nombre de nœuds Kubernetes (total)</b>        | 12              | 40           |
| <b>Bande passante inter-sites (WAN)</b>          | 1 Gbps          | 10 Gbps      |

|                                           |          |          |
|-------------------------------------------|----------|----------|
| <b>Durée de rétention des logs (SIEM)</b> | 12 mois  | 24 mois  |
| <b>Durée de rétention des snapshots</b>   | 30 jours | 90 jours |

Ces valeurs devront être confirmées lors de la phase d'initialisation avec les équipes MOA. Le prestataire devra justifier son dimensionnement dans un document dédié (DAT — Document d'Architecture Technique).

## 5.2 Plages d'exploitation

- Disponibilité cible des services critiques : 24h/24 — 7j/7 — 365j/an
- Fenêtre de maintenance autorisée : samedi 22h00 — dimanche 06h00 (heure Paris), sur validation RSSI et MOA
- Astreinte obligatoire : H24 pour les niveaux P1 (incident critique) et P2 (dégradation majeure)

# 6. Architecture attendue

## 6.1 Vue d'ensemble

L'infrastructure est organisée en quatre zones fonctionnelles distinctes, interconnectées par des liaisons sécurisées. Chaque zone dispose de responsabilités clairement délimitées et d'un niveau de confiance propre dans le modèle Zero Trust.

## 6.2 Site A — Datacenter principal

|                               |                                                                             |
|-------------------------------|-----------------------------------------------------------------------------|
| <b>Rôle</b>                   | Production primaire, orchestration centrale, observabilité globale          |
| <b>Fonctions critiques</b>    | Cluster Kubernetes primaire, IAM central, stockage primaire, SIEM principal |
| <b>Disponibilité requise</b>  | 99,99% (< 52 min d'indisponibilité/an)                                      |
| <b>Niveau de confiance ZT</b> | Contrôlé — toute communication requiert authentification mutuelle           |
| <b>Localisation</b>           | À préciser par le MOA — datacenter certifié Tier III minimum                |

## 6.3 Site B — Datacenter de secours

|                                      |                                                                            |
|--------------------------------------|----------------------------------------------------------------------------|
| <b>Rôle</b>                          | PRA / PCA, réplication temps réel, reprise automatique                     |
| <b>Fonctions critiques</b>           | Nœuds K8s en veille active, réplication synchrone stockage, IAM secondaire |
| <b>Distance minimale recommandée</b> | > 50 km du Site A (risque de catastrophe naturelle commune)                |
| <b>Mode de bascule</b>               | Automatique sur détection de défaillance Site A (RTO < 15 min)             |
| <b>Niveau de confiance ZT</b>        | Identique au Site A — même posture de sécurité                             |
| <b>Localisation</b>                  | À préciser par le MOA — datacenter certifié Tier III minimum               |

## 6.4 Site C — Site industriel distant (Edge)

|                                |                                                                                            |
|--------------------------------|--------------------------------------------------------------------------------------------|
| <b>Rôle</b>                    | Edge computing, traitement local, autonomie en cas de rupture WAN                          |
| <b>Fonctions critiques</b>     | Cluster K8s edge (nœuds légers), cache données critique, applications métier locales       |
| <b>Mode dégradé (WAN down)</b> | Fonctionnement autonome garanti pendant minimum 72h — réconciliation automatique au retour |

|                                |                                                                                   |
|--------------------------------|-----------------------------------------------------------------------------------|
| <b>Contraintes spécifiques</b> | Environnement potentiellement hostile — durcissement physique et logique renforcé |
| <b>Connectivité</b>            | Lien WAN principal + lien 4G/5G de secours minimum                                |

## 6.5 Site D — Zone d'administration sécurisée

|                             |                                                                                             |
|-----------------------------|---------------------------------------------------------------------------------------------|
| <b>Rôle</b>                 | Administration cloisonnée, bastions, supervision sécurité, forensic                         |
| <b>Fonctions critiques</b>  | Bastion SSH/RDP durci, PAM (Privileged Access Management), SIEM secondaire, outils forensic |
| <b>Isolation réseau</b>     | Aucune communication directe avec les sites de production — flux uniquement via bastions    |
| <b>Accès administrateur</b> | Exclusivement depuis cette zone — MFA obligatoire — session enregistrée intégralement       |
| <b>Rétention forensic</b>   | Minimum 12 mois pour les sessions d'administration — 24 mois recommandé                     |

# 7. Contraintes et exigences techniques détaillées

## 7.1 Orchestration Kubernetes multi-sites

### Exigences fonctionnelles

- Haute disponibilité du control plane : minimum 3 nœuds etcd répartis sur Sites A et B (quorum tolérant la perte d'un site)
- Stratégie de fédération à préciser : cluster unique étendu (stretch) ou fédération via KubeFed / Ligo / Admiralty — justification obligatoire dans le DAT
- Latence inter-sites : l'etcd étant sensible à la latence, la RTT entre Sites A et B ne doit pas dépasser 10 ms
- Politiques réseau strictes : NetworkPolicy Kubernetes obligatoires — deny-all par défaut, autorisation explicite uniquement
- Gestion des topologies de pannes : Pod Disruption Budgets, Topology Spread Constraints configurés pour tous les workloads critiques
- Déploiement déclaratif : GitOps obligatoire via ArgoCD ou Flux CD — aucun déploiement manuel en production

### Technologies imposées / recommandées

- CNI réseau : Cilium (recommandé pour la microsegmentation eBPF) ou Calico
- Service Mesh : Istio ou Linkerd pour le mTLS inter-services
- Ingress : NGINX Ingress Controller ou Traefik — WAF intégré obligatoire
- GitOps : ArgoCD (recommandé) ou Flux CD

## 7.2 Interconnexion inter-sites

### Exigences de routage

- Routage dynamique obligatoire : BGP pour l'interconnexion inter-sites, OSPF acceptable en intra-site
- Redondance WAN : minimum deux liens physiquement distincts par site critique (Sites A, B, D)
- Bascule automatique : failover en moins de 30 secondes sur détection de perte de lien
- Chiffrement : tout flux inter-sites chiffré — IPsec IKEv2 (recommandé) ou WireGuard

### Technologies et niveaux de service

| Lien | Bande passante min. | Redondance | Chiffrement |
|------|---------------------|------------|-------------|
|------|---------------------|------------|-------------|

|                        |                    |                      |                     |
|------------------------|--------------------|----------------------|---------------------|
| <b>Site A ↔ Site B</b> | 10 Gbps            | Deux liens distincts | IPsec IKEv2 AES-256 |
| <b>Site A ↔ Site C</b> | 1 Gbps + 4G backup | WAN + 4G/5G          | WireGuard ou IPsec  |
| <b>Site A ↔ Site D</b> | 1 Gbps             | Un lien + VPN backup | IPsec IKEv2 AES-256 |
| <b>Site B ↔ Site D</b> | 1 Gbps             | Un lien minimum      | IPsec IKEv2 AES-256 |

## 7.3 Sécurité — Architecture Zero Trust

### Principes directeurs

- Never trust, always verify : aucune communication n'est implicitement fiable, qu'elle soit interne ou externe
- Least privilege : chaque composant n'accède qu'aux ressources strictement nécessaires à sa fonction
- Assume breach : l'architecture est conçue en assumant qu'une compromission partielle est possible

### Exigences techniques de sécurité

- Segmentation réseau : VLAN dédiés par fonction, ACL strictes, aucun flux non explicitement autorisé
- Microsegmentation : implémentée via le CNI (Cilium/Calico) — politiques par namespace et par label
- MFA obligatoire : pour tout accès administrateur — TOTP minimum, FIDO2/WebAuthn recommandé
- Bastions durcis : accès SSH/RDP uniquement via PAM (CyberArk, HashiCorp Boundary ou équivalent qualifié) — session recording intégral
- Journalisation inviolable : stockage WORM (Write Once Read Many) pour les logs d'audit — horodatage RFC 3161 — rétention minimum 12 mois
- Rotation des secrets : automatisée via HashiCorp Vault ou solution équivalente — aucun secret statique en production
- RBAC strict : contrôle d'accès basé sur les rôles dans Kubernetes et dans toutes les applications — revue trimestrielle des droits
- Gestion des certificats : PKI interne obligatoire (EJBCA ou équivalent) — durée de vie des certificats < 90 jours — renouvellement automatique
- Analyse de vulnérabilités : scan hebdomadaire minimum des images conteneurs et des nœuds — correction sous 72h pour les CVSS ≥ 9.0

## 7.4 Observabilité

### Périmètre

- Métriques : collecte via Prometheus (ou Victoria Metrics pour la volumétrie) — dashboards Grafana — alerting Alertmanager
- Logs : centralisation via Loki ou Elasticsearch/OpenSearch — rétention en ligne 90 jours, archive froide 24 mois
- Traces : distributed tracing via OpenTelemetry — Jaeger ou Tempo comme backend
- Alerting : notification multi-canal (email, messagerie sécurisée, astreinte) — escalade automatique si non-acquittement
- SLO / SLA : définition obligatoire d'au moins 5 SLO par service critique — suivi via error budgets

### Exigences additionnelles

- Corrélation SIEM : tous les logs doivent être ingérés dans le SIEM (Wazuh, Elastic SIEM ou équivalent qualifié ANSSI)
- Tableau de bord de sécurité opérationnel (SOC) : accessible depuis le Site D en temps réel
- Détection d'anomalies : règles de détection comportementale (UEBA) pour les comptes privilégiés

## 7.5 Continuité d'activité (PCA/PRA)

| Indicateur | Objectif | Mécanisme de mise en oeuvre |
|------------|----------|-----------------------------|
|------------|----------|-----------------------------|

|                                       |                        |                                                                                  |
|---------------------------------------|------------------------|----------------------------------------------------------------------------------|
| <b>RPO (Recovery Point Objective)</b> | <b>&lt; 5 minutes</b>  | Réplication synchrone ou semi-synchrone — journaux de transactions               |
| <b>RTO (Recovery Time Objective)</b>  | <b>&lt; 15 minutes</b> | Basculer automatisée — scripts IaC de reconstruction — tests trimestriels        |
| <b>MTTR (Mean Time To Repair)</b>     | <b>&lt; 30 minutes</b> | Runbooks automatisés — astreinte H24 — procédures de rollback testées            |
| <b>Disponibilité annuelle cible</b>   | <b>99,99%</b>          | Redondance active/active ou active/passive selon le composant                    |
| <b>Test PCA</b>                       | <b>Trimestriel</b>     | Test grandeur nature avec validation MOA et RSSI — rapport post-test obligatoire |

Précisions sur le RPO < 5 minutes : atteindre cet objectif implique une réplication synchrone ou quasi-synchrone, ce qui impose une contrainte forte sur la latence entre Sites A et B (RTT < 5 ms recommandé pour le stockage). Le prestataire devra documenter l'impact sur les performances applicatives et proposer des tests de charge validant la compatibilité RPO/performance.

## 7.6 Infrastructure as Code (IaC)

- Couverture IaC : 100% de l'infrastructure doit être décrite en IaC — aucune ressource créée manuellement en production
- Outils : Terraform / OpenTofu pour le provisionning, Ansible pour la configuration, Helm pour les charts Kubernetes
- Gestion des états Terraform : backend distant sécurisé (S3-compatible avec chiffrement) — pas de state file local
- Reproductibilité : un environnement complet doit pouvoir être reconstruit depuis zéro en < 2 heures (hors données)
- Rollback : procédure de retour arrière testée et documentée pour chaque composant critique
- Environnements : au minimum trois environnements distincts — développement, staging (iso-prod), production
- Tests IaC : terratest ou équivalent pour la validation automatisée des modules Terraform

## 7.7 Pipeline CI/CD sécurisé (DevSecOps)

- SAST (Static Application Security Testing) : SonarQube ou Semgrep — bloquant si criticité haute
- SCA (Software Composition Analysis) : Trivy ou Gype — analyse des dépendances et images conteneurs — bloquant si CVSS ≥ 7.0
- Secret detection : Gitleaks ou TruffleHog — intégré au pre-commit et au pipeline CI
- Signature des artefacts : Cosign (sigstore) pour la signature des images conteneurs — vérification obligatoire avant déploiement
- Contrôle de conformité : OPA/Gatekeeper ou Kyverno pour l'enforcement des politiques Kubernetes
- Registre d'images sécurisé : Harbor ou équivalent — analyse automatique à chaque push
- SBOM : génération automatique du Software Bill of Materials (Syft ou Trivy) pour chaque artefact

# 8. Exigences non-fonctionnelles et contraintes de souveraineté

## 8.1 Souveraineté numérique

- Aucune donnée sensible ne doit transiter ou être stockée sur des infrastructures cloud public non qualifiées SecNumCloud
- Les composants logiciels critiques (IAM, SIEM, stockage) doivent être soit open-source auditables, soit issus d'éditeurs qualifiés ANSSI

- L'utilisation de solutions américaines soumises au Cloud Act est interdite pour le traitement des données classifiées
- Privilégier les solutions du catalogue ANSSI et les produits certifiés Critères Communs

## 8.2 Performance

- Latence applicative P95 : < 200 ms pour les requêtes utilisateur standard
- Latence inter-services (microservices) : < 10 ms en intra-site
- Throughput minimum garanti : 1 000 requêtes/seconde par service critique

## 8.3 Scalabilité

- Horizontal Pod Autoscaler (HPA) et Vertical Pod Autoscaler (VPA) configurés pour tous les workloads
- Capacité à absorber un pic de charge x3 par rapport à la charge nominale sans intervention humaine
- Cluster Autoscaler ou Karpenter pour l'autoscaling des nœuds (si infrastructure cloud compatible)

## 8.4 Interopérabilité

- APIs RESTful ou gRPC pour tous les nouveaux services — documentation OpenAPI 3.0 obligatoire
- Formats d'échange standards : JSON, Protobuf, YAML
- Compatibilité avec le SI existant du Ministère : le prestataire devra réaliser une étude d'impact sur les systèmes en place

# 9. Équipe, compétences requises et habilitations

## 9.1 Profils obligatoires

| Profil                                | Nb minimum   | Compétences clés                                                            |
|---------------------------------------|--------------|-----------------------------------------------------------------------------|
| Architecte SI senior                  | 1 (référent) | Architecture cloud-native, Zero Trust, K8s avancé — 8 ans exp. minimum      |
| Ingénieur DevSecOps                   | 2            | CI/CD, IaC (Terraform/Ansible), sécurité pipeline — certif. CKS recommandée |
| Ingénieur sécurité (RSSI prestataire) | 1            | Pentest, durcissement, conformité ANSSI — habilitation DR obligatoire       |
| Ingénieur réseau & telecoms           | 1            | BGP, IPsec, SD-WAN, segmentation — expérience environnements critiques      |
| Ingénieur observabilité               | 1            | Prometheus, Grafana, OpenTelemetry, SIEM                                    |
| Chef de projet technique              | 1            | Coordination MOE, reporting MOA, gestion des risques projet                 |

## 9.2 Habilitations de sécurité

- Niveau Diffusion Restreinte (DR) : obligatoire pour tous les membres de l'équipe ayant accès aux environnements de production
- Niveau Secret Défense : obligatoire pour le référent sécurité et l'architecte SI si traitement de données classifiées
- Le prestataire devra fournir la liste nominative des intervenants avec leurs niveaux d'habilitation avant le démarrage du projet
- Toute intervention d'un personnel non habilité est formellement interdite — le prestataire est responsable du contrôle d'accès de son équipe

## 10. Livrables attendus

| #   | Livrable                                       | Jalon | Description                                                                        |
|-----|------------------------------------------------|-------|------------------------------------------------------------------------------------|
| L1  | DAT — Document d'Architecture Technique        | J+30  | Architecture cible détaillée, choix technologiques justifiés, schémas réseau       |
| L2  | Dossier de sécurité (DSécurité)                | J+45  | Analyse de risques, mesures de sécurité, plan d'homologation ANSSI                 |
| L3  | Environnement de développement opérationnel    | J+60  | IaC complet, pipelines CI/CD, cluster K8s dev                                      |
| L4  | Environnement de staging (iso-prod)            | J+90  | Replica de l'architecture de production — tests de charge et PCA                   |
| L5  | Infrastructure de production Sites A & B       | J+120 | Déploiement Sites A et B avec réplication et bascule automatique                   |
| L6  | Infrastructure Site C (Edge) et Site D (Admin) | J+150 | Déploiement complet, mode dégradé validé, bastions opérationnels                   |
| L7  | Plateforme d'observabilité et SIEM             | J+150 | Métriques, logs, traces, alerting, tableaux de bord SOC                            |
| L8  | Tests PCA/PRA — Rapport de recette             | J+165 | Test grandeur nature, rapport d'incidents, validation MOA/RSSI                     |
| L9  | Documentation d'exploitation (runbooks)        | J+175 | Procédures opérationnelles, gestion des incidents, astreinte                       |
| L10 | Transfert de compétences et formation          | J+180 | Formation des équipes internes — 5 jours minimum — support post-déploiement 3 mois |

## 11. Budget et modalités financières

### 11.1 Enveloppe budgétaire

L'enveloppe budgétaire globale du projet sera précisée par le MOA dans le cadre de l'appel d'offres. Le prestataire devra décomposer son offre financière selon les postes suivants :

- Infrastructure matérielle et logicielle (licences, abonnements)
- Prestations de services (ingénierie, déploiement, formation)
- Coûts d'exploitation annuels (TMA, support, licences récurrentes)
- Coûts de mise en conformité sécurité (audits, pentests, homologation)

### 11.2 Conditions contractuelles

- Pénalités de retard : 0,5% du montant total par semaine de retard au-delà de J+14 sur les jalons critiques (L5, L6, L8)
- Garantie de bon fonctionnement : 12 mois à compter de la recette définitive
- SLA d'exploitation (si TMA incluse) : résolution P1 < 4h, P2 < 8h, P3 < 48h — pénalités sur non-respect
- Clause de réversibilité : le prestataire s'engage à faciliter la transition vers un autre prestataire — documentation complète et transfert des accès sous 30 jours
- Propriété intellectuelle : tous les développements spécifiques et la documentation sont cédés au Ministère à la recette définitive

## 12. Critères d'évaluation des offres

| Critère                                              | Pondération | Éléments d'appréciation                                            |
|------------------------------------------------------|-------------|--------------------------------------------------------------------|
| Qualité technique de l'architecture proposée         | 35%         | Cohérence, résilience, conformité aux exigences, innovation        |
| Compétences et références de l'équipe                | 25%         | CV, habilitations, projets similaires dans des contextes critiques |
| Conformité aux exigences de sécurité et souveraineté | 20%         | Respect LPM, ANSSI, Zero Trust, solutions souveraines              |
| Coût total de possession (TCO)                       | 15%         | Prix, coûts récurrents, rapport qualité/prix                       |
| Méthodologie et gestion des risques projet           | 5%          | Planning, identification des risques, plan de mitigation           |

## 13. Annexes

### Annexe A — Glossaire

| Terme       | Définition                                                                                                    |
|-------------|---------------------------------------------------------------------------------------------------------------|
| DR          | Diffusion Restreinte — premier niveau de classification des informations sensibles en France                  |
| IaC         | Infrastructure as Code — pratique consistant à gérer l'infrastructure via du code versionné                   |
| OIV         | Opérateur d'Importance Vitale — statut réglementaire imposant des obligations renforcées de sécurité          |
| PAM         | Privileged Access Management — solution de gestion des accès à privilèges                                     |
| PCA / PRA   | Plan de Continuité / Reprise d'Activité                                                                       |
| RPO         | Recovery Point Objective — perte de données maximale admissible                                               |
| RTO         | Recovery Time Objective — durée maximale d'interruption admissible                                            |
| SBOM        | Software Bill of Materials — inventaire des composants logiciels d'un artefact                                |
| SecNumCloud | Qualification ANSSI pour les prestataires de services cloud hébergeant des données sensibles                  |
| SIEM        | Security Information and Event Management — outil de centralisation et corrélation des événements de sécurité |
| SOC         | Security Operations Center — équipe et outils dédiés à la surveillance et réponse aux incidents de sécurité   |
| WORM        | Write Once Read Many — technologie de stockage immuable garantissant l'intégrité des données                  |
| ZT / ZTA    | Zero Trust / Zero Trust Architecture — modèle de sécurité basé sur la vérification systématique               |

### Annexe B — Documents de référence

- ANSSI — Référentiel Général de Sécurité (RGS) v2.0
- ANSSI — Guide de sécurité des architectures Zero Trust
- ANSSI — Référentiel SecNumCloud
- NIST Special Publication 800-207 — Zero Trust Architecture
- NIST SP 800-190 — Application Container Security Guide
- Loi de Programmation Militaire 2024-2030 — Titre III (cybersécurité)

- Directive NIS2 — Transposition en droit français
- ISO/IEC 27001:2022 — Systèmes de management de la sécurité de l'information

## Annexe C — Contacts

|                                         |                  |
|-----------------------------------------|------------------|
| <b>Responsable MOA (DSI)</b>            | Pierre DUBREUIL  |
| <b>RSSI</b>                             | Anne BEAUREGARD  |
| <b>Contact appel d'offres</b>           | Catherine HOUYER |
| <b>CALID / COMCYBER (contact cyber)</b> | Yves VAUGIRARD   |

---

*Fin du document — CDC-SI-MULTISITES-2026 v1.0*